



AWS Identity and Access Management (IAM)

© 2020, Amazon Web Services, Inc. ou sua afiliada. Todos os direitos reservados.

Este módulo apresenta o AWS Identity and Access Management (IAM).



O que você aprenderá

Principais pontos da lição

Você aprenderá a:

- Descrever o serviço AWS Identity and Access Management (IAM).
- Citar os diferentes tipos de credenciais de segurança compatíveis com o IAM.
- Descrever como a autenticação e a autorização são implementadas no IAM.



Neste módulo, você aprenderá sobre usuários, grupos e funções do AWS Identity and Access Management (IAM). Você também aprenderá sobre os diferentes tipos de credenciais de segurança.





O AWS Identity and Access Management (IAM) permite gerenciar o acesso aos serviços e recursos da AWS com segurança. Ao usar o IAM, você pode criar e gerenciar usuários e grupos da AWS (para auxiliar na autenticação) e usar permissões para permitir e negar acesso aos recursos da AWS (para auxiliar na autorização).

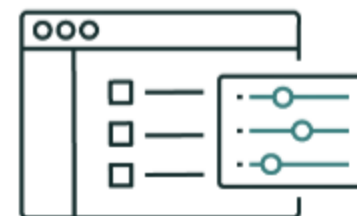
O IAM usa conceitos de controle de acesso que você já conhece, como usuários, grupos e permissões, para que seja possível especificar quais usuários podem acessar serviços específicos.

O que é o IAM?

AWS Identity and Access Management (IAM)

Você pode gerenciar centralmente a autenticação e o acesso aos recursos da AWS.

- Oferecido gratuitamente como um recurso da conta da AWS.
- Crie **usuários, grupos e funções**.
- Aplique **políticas** às entidades para controlar o acesso aos recursos da AWS.



O *AWS Identity and Access Management (IAM)* é um serviço que ajuda a controlar o acesso a recursos da AWS com segurança.

Autenticação

Use o IAM para configurar a *autenticação*, que é a primeira etapa, pois isso controla *quem* pode acessar os recursos da AWS. O IAM é usado para autenticação de usuários e também é usado por aplicativos e outros serviços da AWS para acesso.

Autorização

O IAM é usado para configurar a *autorização*, com base no usuário. A autorização determina *quais* recursos os usuários podem acessar e *o que* eles podem fazer com esses recursos ou como utilizá-los. A autorização é definida por meio do uso de políticas. Uma *política* é um objeto na AWS que, quando associado a uma identidade ou a um recurso, define suas permissões.

O IAM reduz a necessidade de compartilhar senhas ou chaves de acesso ao conceder direitos de acesso a outras pessoas ou sistemas. Isso também facilita a ativação ou a desativação do acesso de um usuário.

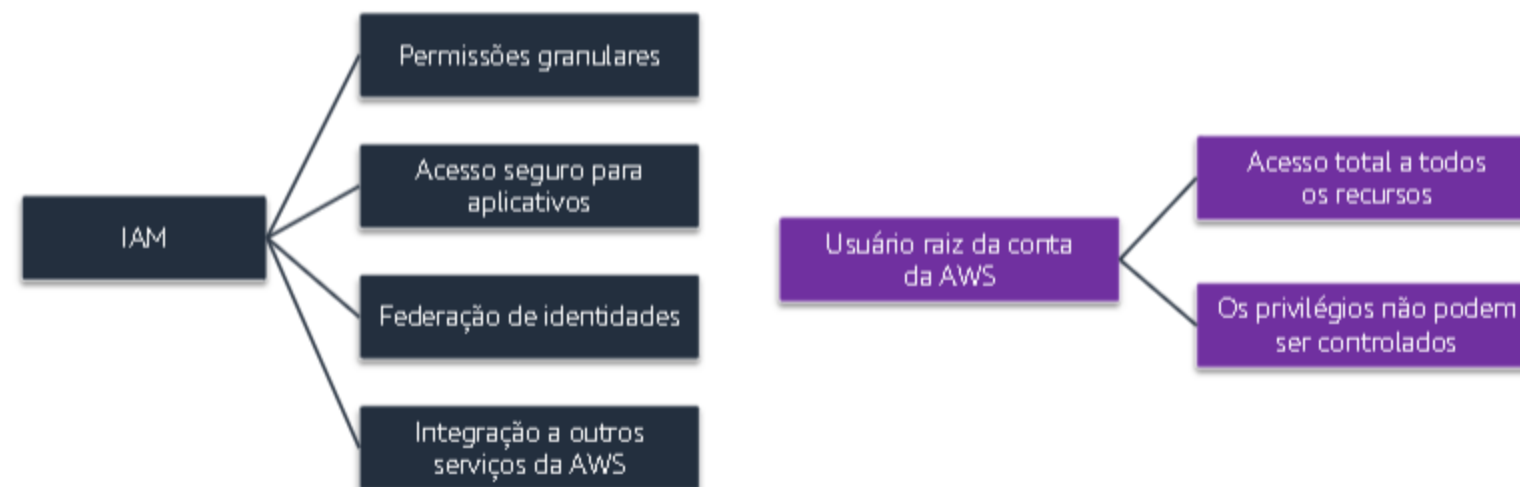
Use o IAM como uma ferramenta para gerenciar de forma centralizada o acesso referente a quem pode iniciar, configurar, gerenciar e fechar os recursos. Ele fornece controle granular sobre as permissões de acesso a usuários,

sistemas ou outros aplicativos que podem fazer chamadas programáticas para outros recursos da AWS.

Use o IAM para realizar as seguintes tarefas:

- Gerencie os recursos que podem ser acessados e as ações que podem ser realizadas nos recursos. Por exemplo, quem tem permissões para fechar instâncias do Amazon Elastic Compute Cloud (Amazon EC2)?
- Defina as credenciais necessárias com base no contexto, como:
 - Quem pode acessar qual serviço da AWS?
 - O que o usuário ou o sistema tem permissão para fazer com o serviço?

Acesso: usuário raiz da conta da AWS em relação ao IAM



Usuário raiz da conta da AWS

Ao criar uma conta da AWS pela primeira vez, você começa com uma identidade de login único. Essa entidade tem acesso completo a todos os serviços e recursos da AWS na conta e é chamada de *usuário raiz da conta da AWS*. O usuário raiz da conta é acessado ao fazer login com o endereço de e-mail e a senha usados para criar a conta.

Os usuários raiz da conta da AWS têm acesso total a todos os recursos na conta. Você não pode controlar as permissões das credenciais de usuário raiz da conta da AWS. Portanto, a AWS recomenda enfaticamente que você não use as credenciais de usuário raiz da conta da AWS para interações do dia a dia com a AWS.

IAM

Use o IAM para criar usuários adicionais e atribuir permissões a eles, seguindo o princípio de privilégio mínimo. Com o IAM, é possível controlar com segurança o acesso de usuários em sua conta da AWS aos serviços e recursos da AWS. Por exemplo, se você precisar de permissões de nível de administrador, você pode

1. Criar um usuário do IAM.
2. Conceder acesso total a esse usuário.
3. Usar essas credenciais para interagir com a AWS.

Posteriormente, se você precisar revogar ou modificar suas permissões, poderá

Princípio do privilégio mínimo

Prática recomendada

- O IAM permite que você siga o princípio do menor privilégio.

O que você deve fazer

- Exclua chaves de acesso do usuário raiz da conta.
- Crie um usuário do IAM.
- Conceda acesso de administrador.
- Ative a autenticação multifator (MFA).
- Use credenciais do IAM para interagir com a AWS.

O princípio do privilégio mínimo é um conceito importante na segurança do computador: determine o que os usuários (e as funções) precisam fazer e,

- Conceda acesso de administrador.
- Ative a autenticação multifator (MFA).
- Use credenciais do IAM para interagir com a AWS.

6



O princípio do privilégio mínimo é um conceito importante na segurança do computador: determine o que os usuários (e as funções) precisam fazer e, então, crie políticas que permitam que eles executem apenas essas tarefas.

Ao criar políticas do IAM, siga a prática de segurança padrão de conceder o privilégio mínimo. Ou seja, conceda apenas as permissões necessárias para realizar uma tarefa. Comece com um conjunto mínimo de permissões e conceda permissões adicionais conforme necessário. Fazer isso é mais seguro do que começar com permissões que são muito lenientes e tentar restringi-las posteriormente.



Tipos de credenciais de segurança

Tipos de credenciais	Associação
Endereço de e-mail e senha	Associado à conta (raiz) da AWS.
Nome de usuário e senha do IAM	Usados para acessar o console de gerenciamento da AWS.
Chaves de acesso e chaves de acesso secretas	Normalmente usadas com a AWS Command Line Interface (AWS CLI) e solicitações programáticas, como interfaces de programação de aplicativo (APIs) e Kits de Desenvolvimento de Software (SDKs).
Multi-Factor Authentication (MFA)	Camada extra de segurança. Pode ser ativada para usuários raiz da conta da AWS e usuários do IAM.
Pares de chaves	Usados apenas para serviços da AWS específicos, como o Amazon EC2.

Este é um resumo dos diferentes tipos de credenciais de segurança da AWS.

Cada conta da AWS tem um usuário raiz de conta atribuído. Esse usuário raiz da

Este é um resumo dos diferentes tipos de credenciais de segurança da AWS.

Cada conta da AWS tem um usuário raiz de conta atribuído. Esse usuário raiz da conta tem um endereço de e-mail atribuído para fins de comunicação e recuperação da conta. No entanto, a AWS recomenda que você não use o usuário raiz da conta para tarefas diárias, mesmo administrativas. Em vez disso, siga as práticas recomendadas de uso do usuário raiz da conta e apenas o utilize para criar seu primeiro usuário do IAM. Depois, bloqueie com segurança as credenciais de usuário raiz da conta. Use-as somente quando você precisar executar as poucas tarefas de gerenciamento de contas e serviços que não podem ser realizadas de outras maneiras.

Como mencionado anteriormente, as credenciais de segurança de nome de usuário e senha do IAM são usadas para acessar o console de gerenciamento da AWS, que também é conhecida como console. As chaves de acesso podem ser usadas para acesso programático quando são geradas para um usuário.

Para maior segurança, a AWS recomenda que você aplique a autenticação multifator (MFA) no usuário raiz da conta da AWS e em qualquer usuário do

IAM: autorização

- Permite que os usuários acessem os serviços da AWS concedendo autorização.
- Atribua permissões criando uma política do IAM.
- As permissões determinam quais recursos e operações têm uso permitido:

Observação: o IAM é global. Não é de acordo com a região. Ele se aplica a todas as regiões AWS.



Depois que um usuário for autenticado, ele deverá ser autorizado a acessar um serviço da AWS.

Para atribuir permissões a um usuário, um grupo ou uma função, você deve criar uma política do IAM. Uma política é um documento que lista as permissões explicitamente. Não há permissões padrão. Todas as ações são negadas por padrão (negação implícita), a menos que sejam explicitamente permitidas. Qualquer ação que você não permita explicitamente é negada. Todas as ações que você negar explicitamente serão sempre negadas.

O IAM é global. Não é de acordo com a região. Ele se aplica a todas as regiões AWS.

MFA

- A **autenticação multifator (MFA)** oferece maior segurança.
- Além do nome de usuário e da senha, a MFA requer um código de autenticação exclusivo para acessar os serviços da AWS.



11

aws re/start

Você pode acessar os serviços e recursos da AWS usando as seguintes ferramentas:

- AWS Management Console
- AWS Command Line Interface (AWS CLI)
- Kits de Desenvolvimento de Software (SDKs) e interfaces de programação de aplicativo (APIs) de uma variedade de ambientes compatíveis

Para aumentar a segurança, a AWS recomenda ativar a MFA. Com a MFA, os

Você pode acessar os serviços e recursos da AWS usando as seguintes ferramentas:

- AWS Management Console
- AWS Command Line Interface (AWS CLI)
- Kits de Desenvolvimento de Software (SDKs) e interfaces de programação de aplicativo (APIs) de uma variedade de ambientes compatíveis

Para aumentar a segurança, a AWS recomenda ativar a MFA. Com a MFA, os usuários e os sistemas devem ser autenticados para que possam acessar os serviços e recursos da AWS. Duas opções são fornecidas para dispositivos de autenticação: dispositivos de hardware e aplicativos virtuais compatíveis com MFA (autenticação de dois fatores do Google Authenticator ou Authy). O Serviço de Mensagens Curtas (SMS) é outra alternativa de autenticação em que você usa seu dispositivo móvel que pode receber mensagens SMS para receber um código.

O AWS Security Token Service (AWS STS) é um serviço da web que também permite solicitar credenciais temporárias de permissão limitada para usuários do IAM ou para usuários autenticados.

Usuários do IAM

- Uma entidade que você cria na AWS
- Oferece uma maneira de interagir com a AWS
- Nenhuma credencial de segurança padrão para usuários do IAM
- Pode representar pessoas ou aplicativos

Prática recomendada

Crie uma conta de usuário do IAM separada com permissões administrativas em vez de usar o usuário raiz da conta da AWS.



Um **usuário** do IAM é uma entidade criada na AWS que fornece uma maneira de interagir com a AWS. Um usuário do IAM fornece principalmente identidades aos indivíduos que eles podem usar para fazer login no console e fazer solicitações aos serviços da AWS.

Os usuários recém-criados do IAM não têm credenciais padrão que podem usar

Um **usuário** do IAM é uma entidade criada na AWS que fornece uma maneira de interagir com a AWS. Um usuário do IAM fornece principalmente identidades aos indivíduos que eles podem usar para fazer login no console e fazer solicitações aos serviços da AWS.

Os usuários recém-criados do IAM não têm credenciais padrão que podem usar para se autenticar e acessar recursos da AWS. Primeiro, atribua credenciais de segurança aos usuários para autenticação. Depois, anexe permissões que autorizem os usuários a executar qualquer ação da AWS ou acessar qualquer recurso da AWS. As credenciais que você cria para os usuários são o que eles usam para se identificar exclusivamente na AWS.

Um usuário do IAM é somente uma identidade com permissões associadas. Você pode criar um usuário do IAM para representar um aplicativo que precisa de credenciais para fazer solicitações à AWS. Um aplicativo pode ter sua própria identidade em sua conta e seu próprio conjunto de permissões, da mesma forma que os processos têm suas próprias identidades e permissões em um sistema operacional, como Microsoft Windows ou Linux.

Uma prática recomendada é criar uma conta de usuário do IAM separada com

Grupos do IAM

Um grupo do IAM é um conjunto de usuários do IAM.

- Coleção de usuários do IAM
- Sem grupos padrão
- Os grupos não podem ser aninhados
- Os usuários podem pertencer a vários grupos

Você pode:

- Especificar permissões para todo o grupo
- Definir permissões usando políticas do IAM



Um **grupo** é um conjunto de usuários do IAM. Os grupos permitem especificar permissões para um conjunto de usuários, o que pode facilitar o gerenciamento das permissões para esses usuários. Por exemplo, você pode ter um grupo

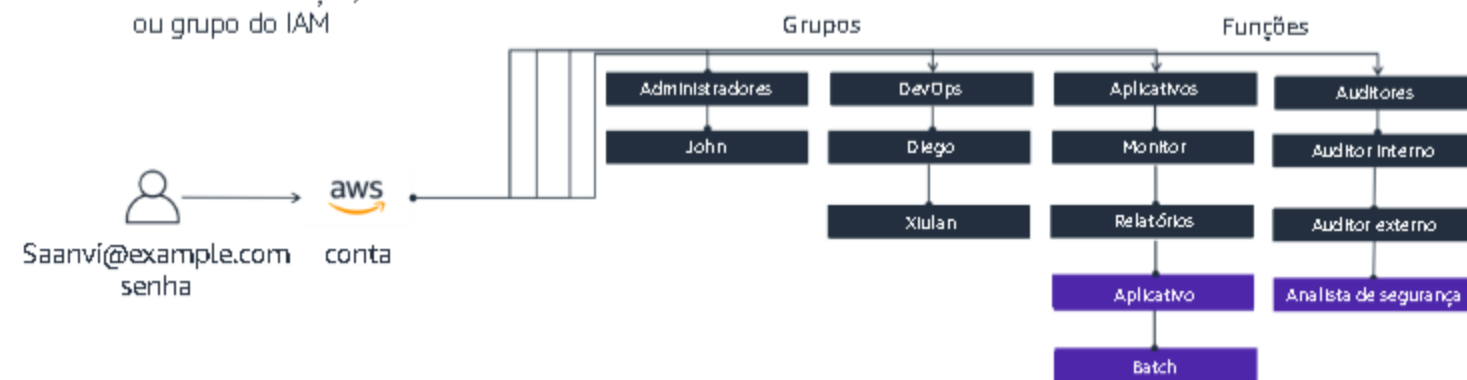
Um **grupo** é um conjunto de usuários do IAM. Os grupos permitem especificar permissões para um conjunto de usuários, o que pode facilitar o gerenciamento das permissões para esses usuários. Por exemplo, você pode ter um grupo chamado **Desenvolvedores** e fornecer a esse grupo os tipos de permissões que os desenvolvedores normalmente precisam. Qualquer usuário nesse grupo tem automaticamente as permissões atribuídas ao grupo. Se um novo usuário ingressar na sua organização e tiver permissões de desenvolvedor, adicione esse usuário ao grupo Desenvolvedores. Isso concede automaticamente a esses usuários as permissões apropriadas. Da mesma forma, se uma pessoa mudar de cargo em sua organização, em vez de editar as permissões desse usuário, você poderá removê-lo do grupo anterior e adicioná-lo ao novo grupo.

Características importantes dos grupos:

- Um grupo pode conter vários usuários, e um usuário pode pertencer a vários grupos.
- Os grupos não podem ser aninhados. Eles podem conter apenas usuários, não outros grupos.
- Não há um grupo padrão que inclua automaticamente todos os usuários na conta da AWS. Se você quiser ter um grupo padrão, é preciso criá-lo e

Funções do IAM

- Usadas para delegar acesso a recursos da AWS
- Fornecem acesso temporário
- Permissões
 - Definidas usando políticas do IAM
 - Anexadas à função, não a um usuário ou grupo do IAM



Uma **função** é uma ferramenta para conceder acesso temporário aos recursos da AWS em sua conta da AWS. As permissões não são anexadas a um usuário ou grupo do IAM. Em vez disso, no tempo de execução, os aplicativos ou serviços da AWS podem assumir uma função de uma forma programática. Quando uma função é atribuída, a AWS retorna credenciais de segurança temporárias que o usuário ou aplicativo pode usar para fazer solicitações programáticas à AWS. Consequentemente, você não precisa compartilhar credenciais de segurança de longo prazo, por exemplo, criando um usuário do IAM, para cada entidade que requer acesso a um recurso.

Casos de uso

Um caso de uso para usar funções é com usuários federados. Um usuário federado não tem uma identidade permanente em uma conta da AWS da mesma forma que um usuário do IAM. Para atribuir permissões a um usuário federado, você pode criar uma entidade de função.

Criar funções

Você cria uma função na conta da AWS que contém os recursos aos quais você deseja permitir acesso. Ao criar a função, especifique duas políticas:

- A política de **confiança** especifica quem tem permissão para assumir a função, como o principal ou a entidade confiável.
- A política de **acesso** (ou **permissões**) define quais ações e recursos o principal tem permissão para usar. O principal pode ser:
 - Conta da AWS
 - Serviço da AWS (como Amazon Elastic Compute Cloud ou Amazon EC2)
 - Provedor de Security Assertion Markup Language (SAML)
 - Provedor de identidade (IdP) que pode incluir Login with Amazon, Facebook ou Google.

O principal também pode ser um usuário, um grupo ou uma função do IAM de outras contas da AWS, incluindo as que não são suas.

Permissões do IAM

Como o IAM determina permissões:



Com o uso das políticas, você pode ajustar as permissões concedidas a usuários, grupos e funções do IAM. Como as políticas são armazenadas no formato JavaScript Object Notation (JSON), você pode usá-las com um sistema de controle de versão. É uma prática recomendada definir o acesso de privilégio mínimo para cada usuário, grupo ou função. Assim, você pode personalizar o acesso a recursos específicos usando uma política de *autorização*.

Quando você determina se as permissões são concedidas, o IAM primeiro verifica se há uma **política de negação explícita**. Se não houver, ele vai então conferir se há uma **política de permissão explícita**. Caso não haja uma política de permissão nem de negação explícita, o IAM reverterá para o padrão: **negação implícita**.

Políticas do IAM

Uma política do IAM é uma declaração formal de uma ou mais permissões.

- Anexe uma política a qualquer entidade do IAM, como usuário, grupo ou função.
- As políticas autorizam as ações que podem, ou não, ser executadas pela entidade.
- Uma única política pode ser anexada a várias entidades.
- Uma única entidade pode ter várias políticas anexadas.

Prática recomendada

Ao anexar a mesma política a vários usuários do IAM, coloque os usuários em um grupo e anexe a política ao grupo.

Uma política do IAM é uma declaração formal de uma ou mais permissões. As políticas podem ser anexadas a qualquer entidade do IAM, o que inclui um usuário, um grupo, uma função ou um recurso. Por exemplo, você pode anexar uma política aos recursos da AWS para bloquear todas as solicitações que não vierem de uma categoria de endereços IP (Internet Protocol) aprovada. As políticas especificam quais ações são permitidas, em quais recursos permitir as ações e qual será o efeito quando o usuário solicitar acesso aos recursos.

A ordem em que as políticas são avaliadas não tem efeito no resultado da avaliação. Todas as políticas são avaliadas, e o resultado é sempre que a solicitação é permitida ou negada. Quando há um conflito, a política mais restritiva prevalece.

Tipos de políticas do IAM

solicitação é permitida ou negada. Quando há um conflito, a política mais restritiva prevalece.

Tipos de políticas do IAM

As **políticas baseadas em identidade** são políticas de permissões que você pode anexar a um principal ou uma identidade, como um usuário, uma função ou um grupo do IAM. Essas políticas controlam quais ações essa identidade pode realizar, em quais recursos e em que condições. As políticas baseadas em identidade podem ser categorizadas como:

- Políticas gerenciadas: políticas independentes baseadas em identidade que você pode anexar a vários usuários, grupos e funções em sua conta da AWS
- Políticas em linha: políticas que você cria e gerencia e que são incorporadas diretamente em um único usuário, grupo ou função
- **Políticas com base em recursos** são documentos de política JSON anexados a um recurso, como um bucket do Amazon Simple Storage Service (Amazon S3). Essas políticas controlam quais ações uma entidade principal pode realizar nesse recurso e em quais condições. As políticas baseadas em recurso são políticas em linha. Não há políticas gerenciadas baseadas em recurso. Para obter mais informações, consulte [Políticas e permissões no IAM](#) no *Guia do usuário do AWS Identity and Access Management*.

- Políticas em linha: políticas que você cria e gerencia e que são incorporadas diretamente em um único usuário, grupo ou função
- **Políticas com base em recursos** são documentos de política JSON anexados a um recurso, como um bucket do Amazon Simple Storage Service (Amazon S3). Essas políticas controlam quais ações uma entidade principal pode realizar nesse recurso e em quais condições. As políticas baseadas em recurso são políticas em linha. Não há políticas gerenciadas baseadas em recurso. Para obter mais informações, consulte [Políticas e permissões no IAM](#) no *Guia do usuário do AWS Identity and Access Management*.

Ao anexar a mesma política a vários usuários do IAM, coloque os usuários em um grupo e anexe a política ao grupo. Além disso, você pode usar o simulador de políticas do IAM para testar e solucionar problemas do IAM e políticas baseadas em recursos. Para saber mais sobre o simulador de políticas do IAM, consulte [Testar políticas do IAM com o simulador de políticas do IAM](#) no *Guia do usuário do AWS Identity and Access Management*.

Exemplo: política do IAM

Política baseada em recursos

```
{
  "Version": "2012-10-17",
  "Statement": [{
    "Effect": "Allow",
    "Action": ["DynamoDB:*", "s3:*"],
    "Resource": ["arn:aws:dynamodb:region:account-number-without-hyphens:table/table-name",
      "arn:aws:s3::bucket-name",
      "arn:aws:s3::bucket-name/*"]
  },
  {
    "Effect": "Deny",
    "Action": ["dynamodb:*", "s3:*"],
    "NotResource": ["arn:aws:dynamodb:region:account-number-without-hyphens:table/table-name",
      "arn:aws:s3::bucket-name",
      "arn:aws:s3::bucket-name/*"]
  }
]
}
```

Uma permissão explícita oferece aos usuários acesso a uma tabela específica do DynamoDB e...

...buckets do Amazon S3.

Uma negação explícita garante que os usuários não possam usar nenhuma outra ação ou recurso da AWS que não seja essa tabela e esses buckets.

Uma instrução de negação explícita tem precedência sobre uma instrução de permissão.

A política de exemplo concede aos usuários acesso apenas aos seguintes recursos:

- A tabela do Amazon DynamoDB cujo nome é representado por *table-name*.
- O bucket do Amazon S3 corporativo da conta da AWS, cujo nome é

A política de exemplo concede aos usuários acesso apenas ao seguintes recursos:

- A tabela do Amazon DynamoDB cujo nome é representado por *table-name*.
- O bucket do Amazon S3 corporativo da conta da AWS, cujo nome é representado por *bucket-name* e todos os objetos que contém.

A política inclui um elemento de negação explícita ("**Effect**":"**Deny**") com o elemento **NotResource**. Essa negação explícita ajuda a garantir que os usuários não possam realizar nenhuma ação da AWS nem usar recursos, exceto aqueles que foram especificados na política (mesmo que as permissões tenham sido concedidas em outra política). Uma instrução de negação explícita tem precedência sobre uma instrução de permissão.

IAM: atribuição de política

Você pode atribuir uma política a um usuário do IAM, um grupo do IAM e a funções do IAM.



18

aws re/start

Você pode atribuir a mesma política a um usuário do IAM, um grupo do IAM e a funções do IAM. Isso permite a reutilização e reduz a necessidade de recriar a mesma política para identidades diferentes.

Principais conclusões



© 2020, Amazon Web Services, Inc. ou suas afiliadas. Todos os direitos reservados.

20

- O AWS Identity and Access Management (IAM) é um serviço que **ajuda a controlar o acesso a recursos da AWS com segurança**.
- O IAM fornece **diferentes tipos de credenciais de segurança**:
 - Endereço de e-mail e senha
 - Nome de usuário e senha do IAM
 - Chaves de acesso e chaves de acesso secretas
 - MFA
 - Pares de chaves
- Use o IAM para criar **usuários** e **grupos** e atribuir **funções** a eles.
- Uma função do IAM especifica **permissões** que definem quais ações podem ser realizadas em relação a determinado recurso.



As principais conclusões desta lição:

- O AWS Identity and Access Management (IAM) é um serviço que ajuda a controlar o acesso a recursos da AWS com segurança.
- O IAM fornece diferentes tipos de credenciais de segurança:
 - Endereço de e-mail e senha